CYBERSECURITY AVANZATA · LEZIONE 6 · ANATOMIA DI UN'E-MAIL

Chi può fingersi te?

Un'azienda locale ti chiede: "Qualcuno può mandare mail che sembrano nostre?". Rispondi con un'analisi di cinque domini veri, letta solo dal DNS pubblico, e consigli concreti.

Cosa consegni: un file **posta-cognome.pdf** (1-2 pagine) su Google Classroom. **Scadenza:** quella indicata su Novaula.

Che cosa devi fare

1. Scegli **5 domini** di tipi diversi: un ente pubblico, una banca o un'assicurazione, un negozio online, un'azienda della tua zona, un giornale.
2. Per ognuno leggi con `nslookup -type=txt` il record **SPF** del dominio e il record **DMARC** in `_dmarc.dominio`.
3. Compila la tabella dell'esempio. Per SPF indica se finisce con `-all`, `~all` o altro; per DMARC la politica `p=` e se ci sono i report (`rua=`).
4. Dai a ogni dominio un giudizio: **protetto** (DMARC reject o quarantine), **in osservazione** (p=none), **scoperto** (niente DMARC).
5. Per il dominio messo peggio scrivi 3 consigli in ordine, come se parlassi all'azienda, e spiega in 3 righe perché DMARC **non** la protegge dai domini sosia.

Esempio di tabella

Dominio	SPF	DMARC	Giudizio
esempio.it	v=spf1 include:… -all	p=quarantine, report sì	protetto

> *"Il fattore umano è davvero l'anello più debole della sicurezza."* · **Kevin Mitnick**, *L'arte dell'inganno (2002). Ma un dominio senza DMARC è un anello debole tecnico, e si sistema in un pomeriggio.*

Come viene valutato

Criterio	Punti
Cinque domini di tipi diversi, record letti correttamente	3
Giudizi coerenti con i record	2
Consigli concreti e nell'ordine giusto	3
Spiegazione corretta sui domini sosia	2

Si leggono solo record DNS pubblici. Non si inviano mail di prova a nome di altri: anche per gioco è sostituzione di persona (art. 494 c.p.).